BÁO CÁO GIẢI PHÁP & ĐỀ XUẤT STACK CÔNG NGHỆ HMS

Hệ thống Quản lý Homestay: Phương án Triển khai, Xử lý Lỗ hổng & Đề xuất Hạ tầng

> **Dự án:** Homestay Management System (HMS) | **Căn cứ BA:** Phần 1 v0.2 - Phần 4 v0.1 | **Ngày lập:** 04/11/2026

1. Executive Summary & Bối cảnh Dự án

Báo cáo này tổng hợp phương án xử lý toàn diện cho 12 câu hỏi Blocking [Q] cùng 10 vấn đề nghiệp vụ mở, đồng thời thiết lập **Stack Công nghệ chuẩn hóa** cho Hệ thống Quản lý Homestay (HMS). Hệ thống hướng tới giải quyết triệt để sự cố trùng phòng (double booking), chống thất thoát tài chính, bảo mật tuyệt đối dữ liệu cá nhân khách hàng (tuân thủ Luật Bảo vệ Dữ liệu Cá nhân 2025 & NĐ 356/2025) và đảm bảo tính liên tục vận hành trong môi trường chuỗi homestay đa cơ sở.

2. Tổng hợp Giải đáp 12 Câu hỏi Blocking [Q] & Giả định Tạm thời (ASM)

Tài liệu BA v0.2 ghi nhận 12 câu hỏi Blocking cấp thiết. Dưới đây là bảng tổng hợp các giả định tạm thời (ASM) đã được thống nhất để đưa vào khung thiết kế Baseline:

Mã OQ	Câu hỏi Blocking [Q]	Phụ trách	Phương án Xử lý Tạm thời (ASM) / Giải pháp
OQ-014	Chế độ thuế & Thuế suất? Phí hủy chịu thuế không?	Kế toán (SH-04)	Hệ thống hỗ trợ linh hoạt cả 2 chế độ (giá gồm thuế và chưa gồm thuế); công thức tính tiền tự động bóc tách.
OQ-015	Lộ trình Hóa đơn điện tử theo NĐ 70/2025?	Kế toán (SH-04)	MVP xuất phiếu thu nội bộ & kết xuất dữ liệu sang phần mềm kế toán (MISA/Fast). Tích hợp HĐĐT tự động ở Phase 2.
OQ-019	Tuân thủ Luật BVDLCN 2025 & NĐ 356/2025?	Owner + Luật sư	Thu thập dữ liệu tối thiểu, mã hóa CSDL (Argon2id/KMS), lưu trữ 5 năm, ẩn danh hóa khi có yêu cầu hợp lệ.
OQ-037	Hình thức pháp lý & Nghĩa vụ HĐĐT máy tính tiền?	Owner + Kế toán	Cấu hình hình thức pháp lý riêng cho từng cơ sở (Hộ kinh doanh / Doanh nghiệp); sẵn sàng cổng kết xuất dữ liệu.
OQ-001	Đơn vị bán phòng: phòng riêng, cả căn, giường dorm?	Owner (SH-01)	ASM-001: Bán phòng riêng + bán cả căn (Villa); ERD thiết kế cấu trúc Cha-Con (parent_id) hỗ trợ giường dorm.
OQ-002	Có hỗ trợ thuê theo giờ hoặc dài hạn (long-stay)?	Owner (SH-01)	ASM-002: Trong giai đoạn MVP chỉ hỗ trợ lưu trú ngắn ngày tính theo đêm.
OQ-005	Có chấp nhận Overbooking có kiểm soát không?	Owner (SH-01)	ASM-005: Mặc định cấm. Manager override tạo booking cờ Conflict (không sinh RoomNight) đưa vào hàng chờ.
OQ-008	Chính sách Hủy, No-show & Trả phòng sớm?	Owner (SH-01)	ASM-008: Cấu hình nhiều chính sách gắn theo Rate Plan; No-show tính phí đêm 1; đơn có cọc giữ phòng đêm 1.
OQ-016	Doanh thu ghi nhận theo ngày ở hay ngày thu tiền?	Owner + Kế toán	ASM-016: Hỗ trợ cả 2; mặc định báo cáo doanh thu tiền phòng theo đêm lưu trú thực tế (accrual).

Mã OQ	Câu hỏi Blocking [Q]	Phụ trách	Phương án Xử lý Tạm thời (ASM) / Giải pháp
OQ-020	Phương án tích hợp các kênh OTA?	Owner (SH-01)	ASM-020: Tích hợp 1 Channel Manager bên thứ 3 có API ở Phase 2; Phase 1 nhập tay đơn OTA và chặn phòng thủ công.
OQ-031	Ràng buộc Dự án: Ngân sách, Deadline, Đội ngũ?	Owner (SH-01)	Cần phê duyệt tại Workshop đợt 0 để chốt chính xác thời lượng triển khai cho Roadmap.
OQ-032	Mô hình triển khai: Nội bộ hay SaaS Multi-tenant?	Owner (SH-01)	ASM-032: Triển khai Single-tenant Multi-property (1 chủ nhiều cơ sở), CSDL thiết kế sẵn trường tenant_id.

3. Hướng Xử lý Chuyên sâu cho 10 Bài toán Nghiệp vụ Mở

Bên cạnh các câu hỏi Blocking, hệ thống quy định giải pháp kiến trúc chuyên sâu cho 10 rủi ro vận hành trọng yếu nhằm đảm bảo tính chính xác về tài chính và an toàn dữ liệu:

STT	Vấn đề Nghiệp vụ / Câu hỏi Mở	Module	Phương án Giải pháp Thiết kế Chuyên sâu
1	Tiền cọc về muộn khi Booking đã Expired / Cancelled	BOOK, PAY	Khoản tiền đối soát sau Expired tự động vào tài khoản 'Chờ phân bổ' (UnallocatedReceipt). Còn phòng: Khôi phục booking theo giá hiện hành. Hết phòng: Hoàn 100% hoặc đổi sang Tín dụng khách (GuestCredit - hạn 12 tháng).
2	Đoàn / Đặt nhiều phòng & Tách chi phí Folio	INV, BOOK	Hệ thống tự động mở Master Folio (công ty/trưởng đoàn trả tiền phòng) và Individual Folio (khách trả dịch vụ lẻ). Áp dụng quy tắc FolioRoutingRule tự động phân bổ dòng chi phí.
3	Khách hàng Blacklist - Chặn hay Cảnh báo?	GST, BOOK	Cơ chế Cảnh báo kèm Phê duyệt (Warning with Approval). Lễ tân tạo đơn cho khách Blacklist bắt buộc có phê duyệt từ Manager kèm lý do giải trình và lưu vết Audit Log.
4	Tắc nghẽn Maker-Checker khi ca trực 1 người	RBAC, PAY	1) Phê duyệt từ xa qua Mobile App 2FA. 2) Owner được tự duyệt nếu đứng ca nhưng bắt buộc nhập lý do và tự động đưa vào Báo cáo Ngoại lệ. 3) Cấp ngưỡng tự do cho Lễ tân <= 10%.
5	Đối soát chuyển khoản thủ công chống gian lận	PAY	Nhúng mã tham chiếu duy nhất (VD: HMS7K3P9Q2) vào VietQR động. Cung cấp tính năng Upload file sao kê CSV/Excel ngân hàng; thuật toán tự động gợi ý khớp dòng giao dịch, mỗi dòng sao kê chỉ khớp 1 lần.
6	Quản lý Quỹ tiền mặt & Đóng ca thu ngân	PAY	Áp dụng Đếm mù (Blind Count) khi đóng ca: Lễ tân bắt buộc nhập số tiền thực tế mà không nhìn thấy số hệ thống tính. Mọi giao dịch tiền mặt bắt buộc gắn ca mở (Shift). Lệch quỹ tự động chuyển Manager xác minh.
7	Kích hoạt thủ công hay Tự động Night Audit?	FO-NA	Cho phép Night Auditor kích hoạt thủ công trong khung 00:00 - 06:00. Đặt lịch nhắc nhở lúc 23:30; quá 06:00 sáng hôm sau chưa chạy sẽ phát Alert cảnh báo khẩn tới Owner/Manager.
8	App Buồng phòng mất mạng Offline	HK	App HK lưu trạng thái tạm trên bộ nhớ máy (Local Storage). Khi có mạng, tự động đồng bộ về Server kèm task_id và version. Nếu xung đột (Lễ tân đã đổi phòng), Server từ chối bản ghi cũ.
9	Khóa OOO đột xuất khi phòng đã có khách đặt	MNT, CAL	Hệ thống từ chối tạo OOO trực tiếp nếu phòng đã có RoomNight hiệu lực. Bắt buộc Manager phải Đổi phòng (Room Move) hoặc Nâng hạng (Upgrade) miễn phí cho khách trước rồi mới sinh RoomBlock OOO.

STT	Vấn đề Nghiệp vụ / Câu hỏi Mở	Module	Phương án Giải pháp Thiết kế Chuyên sâu
10	Bảo vệ dữ liệu CCCD/Hộ chiếu & Luật BVDLCN	GST, AUD	Mặc định che (Masked) 4 số cuối CCCD và 3 số cuối SĐT. Quyền xem đầy đủ (Unmasking) chỉ cấp cho R-OWN, R-MGR, R-FD, R-NA và mỗi lần bấm xem đều bắt buộc ghi Audit Log. CSDL mã hóa Argon2id/KMS + Blind Index HMAC.

4. Đề xuất Kiến trúc Stack Công nghệ (Technology Stack Proposal)

Dựa trên các ràng buộc kỹ thuật NFR và yêu cầu kiểm soát tồn phòng nguyên tử, đội ngũ kiến trúc đề xuất Bộ giải pháp Stack Công nghệ toàn diện dưới đây:

Tầng Kiến trúc	Công nghệ Đề xuất	Đặc tính & Lý do Lựa chọn	Đáp ứng Quy tắc / NFR
Database Core	PostgreSQL 16+	Hỗ trợ Partial Unique Index, CHECK Constraint, Row-Level Security (RLS) cách ly cơ sở và JSONB lưu snapshot giá.	NFR-DATA-001, BR-010, BR-013, BR-060
Caching & Queue	Redis 7.x + BullMQ	Bộ nhớ đệm Session/Token, Pub/Sub phát sự kiện real-time cho ma trận Lịch phòng, Hàng chờ ngầm cho Night Audit & Webhook.	NFR-PERF-001, BR-011, BR-072
Backend Core	Node.js (NestJS) + TypeScript	Kiến trúc Modular Monolith chuẩn hóa, xử lý I/O bất đồng bộ hiệu năng cao, Type-safe end-to-end, tích hợp Prisma/TypeORM RLS.	FR-RBAC-003, NFR-SEC-002, BR-064
Frontend Web	React 18 (Next.js) + Tailwind CSS	Giao diện Back-office phản hồi nhanh, ma trận Room Calendar kéo thả mượt mà, quản lý state TanStack Query + Zustand.	BG-03, NFR-PERF-001, FR-CAL-003
Mobile App	Flutter / React Native	Ứng dụng vận hành cho Buồng phòng & Bảo trì, giao diện tối giản không hiện thông tin cá nhân khách, hỗ trợ Sync bộ nhớ tạm.	OQ-035, BR-066, FR-HK-004
Security & Crypto	Argon2id + AES-256-GCM + HMAC	Băm mật khẩu/PIN bằng Argon2id, mã hóa ảnh/số CCCD bằng AES-256/KMS, tra cứu tìm trùng bằng Blind Index (HMAC-SHA256).	NFR-SEC-003, BR-063, BR-065
Deployment	Docker + Kubernetes / AWS ECS	Container hóa hạ tầng, triển khai tự động CI/CD, sẵn sàng scale mở rộng, đáp ứng cam kết SLA Uptime 99.5%/tháng.	NFR-AVL-001, RPO <= 15m, RTO <= 4h

5. Ma trận Rủi ro Công nghệ & Lộ trình Go-Live 5 Bước

Các rủi ro công nghệ trọng yếu:

• *Lệch tồn phòng OTA Phase 1:* Do nhập tay, giải quyết bằng Báo cáo 'Booking OTA chưa nhập' và quy trình đóng phòng thủ công ngay khi bán trực tiếp.

• *Tranh chấp dữ liệu (Race Conditions):* Cưỡng chế bằng ràng buộc CSDL UNIQUE(room_id, stay_date) và Optimistic Locking (version).

• *Rủi ro giả mạo Webhook:* Bắt buộc xác thực chữ ký HMAC Signature và Idempotency Key cho mọi Webhook ngân hàng/OTA (BR-073).

• *Gian lận Sửa/Xóa Audit Log:* Chuỗi mã hóa Hash-Chain (prev_hash SHA-256) phát hiện đứt chuỗi tức thì nếu CSDL bị can thiệp trực tiếp.

Quy trình Triển khai & Cắt chuyển Go-Live (Cut-over):

1. **Workshop Đợt 0 (2 giờ):** Thống nhất và duyệt ký văn bản 12 câu hỏi Blocking [Q] với Business Owner & Kế toán.
2. **Kiểm kê & Nhập Dữ liệu Chủ:** Thu thập booking tương lai từ Excel/Sổ sách; thiết lập cơ sở, phòng, bảng giá và phân quyền.
3. **Nhập Booking Tương lai:** Nạp dữ liệu qua luồng kiểm tra tồn nguyên tử (không ghi thẳng CSDL); xung đột đưa vào hàng chờ Conflict.
4. **Đào tạo & Chạy Pilot:** Đào tạo nhân sự theo ca trực; vận hành Pilot 4 tuần tại 1 cơ sở tiêu biểu trước khi nhân rộng.
5. **Cut-over Chuyển đổi:** Chuyển đổi chính thức vào ngày thấp điểm; khóa sổ cũ và sử dụng HMS là Nguồn dữ liệu chuẩn (Source of Truth).